ACTIVIDAD DE APRENDIZAJE · MISIÓN BÁSICA 4

Guardianes de Tekhne: seguridad de la información, normativa y controles en talento humano

Reconocer qué se debe proteger, evaluar riesgos con una matriz y proponer controles según ISO/IEC 27001, el GDPR y la Ley 1581 de 2012

Programa	Técnico en Talento Humano (SENA)	**Duración**	90 minutos
Competencia	Operación de herramientas informáticas y digitales para talento humano	**Modalidad**	Presencial; equipos de 4 a 5 aprendices
Tema	Seguridad de la información: normativa (ISO 27001, GDPR, Ley 1581) y controles	**Guía base**	«Retos del planeta Byteon» – Misión básica 4

1. Propósito

Al terminar, el aprendiz relaciona incidentes con las propiedades de la seguridad, clasifica controles, calcula y prioriza riesgos con una matriz, y propone acciones basadas en ISO/IEC 27001, el GDPR y la normativa colombiana.

Resultados esperados

- Relacionar cinco incidentes con confidencialidad, integridad, disponibilidad, autenticidad o trazabilidad.
- Clasificar 12 prácticas de seguridad en cinco categorías de control.
- Calcular el riesgo de cinco hallazgos, ordenarlos por prioridad y proponer control, norma y responsable.
- Completar un mapa de defensa en capas y responder ante una brecha de datos.

Materiales

- Anexo 1 (incidentes y tarjetas), Anexo 2 (caso de Tekhne), Anexo 3 (matriz de riesgos) y Anexo 4 (mapa de defensa): uno por equipo.
- Calculadora, marcadores, papel kraft y cronómetro. Anexos 5 y 6 solo para el instructor.

2. Ruta de la sesión (90 minutos)

Momento	Min	Qué se hace	Grupo	Evidencia
1. Alarma en Tekhne	10	Activación: mensaje de LucIA y cinco incidentes por relacionar.	Equipos	Incidentes relacionados
2. Normas y controles	15	Mini-explicación (5 min) y clasificación de 12 prácticas (10 min).	Equipos	Tarjetas clasificadas
3. Misión principal	35	Auditar el área de talento humano de Byteon: calcular riesgos y proponer controles.	Equipos	Matriz y mapa (producto)
4. Reporte a DataPrime	15	Cada equipo expone 3 minutos y recibe preguntas.	Plenaria	Reporte oral (desempeño)
5. Cierre y verificación	15	Cuestionario de 5 preguntas, mini-caso de brecha de datos y autoevaluación.	Individual	Cuestionario (conocimiento)

3. Desarrollo paso a paso

Momento 1 · Alarma en Tekhne (10 min)

Instructor: lee el mensaje: «Aquí LucIA. Los sistemas que dejó Aspís-Dóry en Tekhne registran cinco alertas en el área de talento humano de Byteon. Antes de actuar, identifiquen qué propiedad de la información se está perdiendo en cada una».

- Cada equipo relaciona, en la Parte A del Anexo 1, cada incidente con la propiedad afectada: confidencialidad, integridad, disponibilidad, autenticidad o trazabilidad.

Momento 2 · Normas y controles (15 min)

- **Mini-explicación (5 min):** seguridad de la información = proteger confidencialidad, integridad y disponibilidad. ISO/IEC 27001 pide un sistema de gestión basado en riesgos; el GDPR y la Ley 1581 de 2012 protegen los datos personales y exigen medidas de seguridad. Los controles se agrupan en hardware, software, acceso, cifrado y personas.
- **Clasificación (10 min):** con las 12 tarjetas de la Parte B del Anexo 1, cada equipo asigna cada práctica a una categoría y defiende en voz alta una tarjeta difícil.

Momento 3 · Misión principal: auditoría en Tekhne (35 min)

Con el caso del Anexo 2, cada equipo audita el área de talento humano de Byteon:

- **Calcular (10 min):** con la probabilidad y el impacto de cada hallazgo (Anexo 3), calcular riesgo = probabilidad × impacto y asignar el nivel: 1 a 5 bajo; 6 a 11 medio; 12 a 19 alto; 20 a 25 crítico.
- **Proponer (15 min):** para cada hallazgo, indicar la propiedad afectada, un control concreto, la norma que lo respalda y un responsable. Ordenar los hallazgos por prioridad.
- **Dibujar (10 min):** completar el mapa de defensa en capas (Anexo 4), con al menos un control por capa, y marcar dónde cada hallazgo rompió la defensa.

Momento 4 · Reporte a DataPrime (15 min)

- Cada equipo expone en 3 minutos el hallazgo más crítico, el cálculo, el control propuesto y el orden de prioridad.
- DataPrime (el instructor) formula una pregunta por equipo, por ejemplo: ¿por qué atender primero un riesgo de 20 aunque el de 15 sea más probable? Los demás equipos aportan una mejora.

Momento 5 · Cierre y verificación (15 min)

- **Cuestionario individual (5 min):** sección 4.
- **Mini-caso (5 min):** el viernes a las 10:00 a. m. se descubre que la nómina de 300 empleados se envió por error a un correo externo. En parejas: ¿qué debe hacerse y en qué plazo? (contener y documentar, avisar al responsable y al oficial de datos, evaluar el alcance; informar a la SIC y a los titulares según la ley colombiana; si hay personas en la UE, notificar a la autoridad en un máximo de 72 horas).
- **Autoevaluación (5 min):** tabla de la sección 5.

4. Cuestionario de verificación

N°	Pregunta	Opciones
1	La tríada clásica de la seguridad de la información es…	a) costo, impacto, daño b) confidencialidad, integridad y disponibilidad c) control, inventario, datos
2	ISO/IEC 27001 especifica los requisitos de…	a) un hardware seguro b) una ley de la UE c) un sistema de gestión de seguridad de la información (SGSI)
3	Según el GDPR, una brecha de datos debe notificarse a la autoridad, si es posible, en…	a) 7 días b) 72 horas c) un año
4	Dar a cada persona solo los permisos que necesita es el principio de…	a) redundancia b) trazabilidad c) mínimo privilegio
5	La autoridad de protección de datos personales en Colombia es…	a) la DIAN b) la Superintendencia de Industria y Comercio c) el DANE

Respuestas para el instructor: 1-b, 2-c, 3-b, 4-c, 5-b.

5. Autoevaluación del aprendiz

Afirmación	Sí	Parcialmente	No
Puedo explicar confidencialidad, integridad, disponibilidad, autenticidad y trazabilidad.	[ ]	[ ]	[ ]
Distingo ISO/IEC 27001 (gestión de seguridad) del GDPR y la Ley 1581 (protección de datos).	[ ]	[ ]	[ ]
Puedo calcular y priorizar riesgos con una matriz de probabilidad por impacto.	[ ]	[ ]	[ ]
Identifico controles de hardware, software, acceso, cifrado y personas.	[ ]	[ ]	[ ]
Participé y contribuí al trabajo de mi equipo.	[ ]	[ ]	[ ]

Una cosa que aprendí hoy: _____

Anexo 1 · Incidentes y tarjetas

Parte A. Escriba qué propiedad se afecta: confidencialidad, integridad, disponibilidad, autenticidad o trazabilidad.

N°	Incidente	Propiedad afectada
1	Un practicante puede ver la nómina de toda la empresa aunque no le corresponde.	
2	Alguien cambia sin permiso el salario de un empleado en la base de datos.	
3	El servidor de nómina falla el día de pago y nadie puede liquidar.	
4	Se descubre que un usuario ingresó con la clave de un compañero.	
5	No se sabe quién modificó un contrato porque el sistema no guarda registros.	

Parte B. Clasifique cada práctica: H hardware o seguridad física, S software, A control de acceso, C cifrado, P personas y procedimientos.

N°	Práctica	Cat.
1	Candado y cámara en el archivo de hojas de vida.	
2	Instalar cada mes los parches del sistema de nómina.	
3	Cada analista ve solo las hojas de vida de su sede.	
4	Disco del portátil cifrado con BitLocker.	
5	Firma de un acuerdo de confidencialidad al ingresar.	
6	Autenticación multifactor para entrar a la nómina.	
7	Antivirus actualizado en todos los equipos.	
8	Lector biométrico en la puerta del cuarto de servidores.	
9	Desprendibles de pago enviados en PDF cifrado con clave.	
10	Capacitación anual para reconocer correos de phishing.	
11	Puertos USB deshabilitados en los equipos con datos de personal.	
12	Revocar el mismo día todos los accesos de quien se retira.	

Anexo 2 · Caso: auditoría en Tekhne

Escenario ficticio para el ejercicio. Las cifras son inventadas.

Situación: DataPrime encargó a su equipo una auditoría rápida del área de talento humano de Byteon, que maneja datos de 300 neógenos, incluidos salarios, cuentas bancarias y datos de salud. Los sistemas de Tekhne detectaron cinco hallazgos. Debe decidirse qué corregir primero con recursos limitados.
Pregunta clave: ¿qué riesgos se atienden primero y con qué controles?

Hallazgo	Descripción
H1	Las hojas de vida están en una carpeta compartida sin contraseña, abierta a todo el personal.
H2	El computador de nómina lleva 8 meses sin parches ni actualizaciones.
H3	Un exempleado conserva acceso al sistema de nómina 3 meses después de su retiro.
H4	Los desprendibles de pago se envían por correo sin cifrar a cuentas personales.
H5	No existen copias de seguridad probadas del archivo de personal.

Anexo 3 · Matriz de riesgos (para diligenciar)

P = probabilidad e I = impacto (escala de 1 a 5); riesgo = P × I. Nivel: 1 a 5 bajo; 6 a 11 medio; 12 a 19 alto; 20 a 25 crítico.

Hall.	P	I	Riesgo	Nivel	Propiedad	Control, norma y responsable	Prior.
H1	4	4					
H2	4	5					
H3	3	5					
H4	3	3					
H5	2	5					

Normas de apoyo: ISO/IEC 27001:2022, Anexo A (por ejemplo 5.15 control de acceso, 6.5 terminación del empleo, 8.8 vulnerabilidades, 8.13 copias de seguridad, 8.24 criptografía); GDPR art. 32; Ley 1581 de 2012, arts. 4 y 17.

Anexo 4 · Mapa de defensa en capas

Escriba al menos un control por capa y marque con el número del hallazgo (H1 a H5) dónde se rompió la defensa.

Capa	Qué protege	Controles propuestos	Hallazgo roto
Personas y procedimientos	Quien usa los datos		
Seguridad física	Salas, archivos, servidores		
Red	Tráfico y conexiones		
Equipo (hardware)	Computadores y dispositivos		
Aplicación (software)	Nómina, selección, correo		
Datos	Expedientes y bases		

Política de una línea para el área de talento humano (por ejemplo, sobre envío de datos personales):

Conclusión del equipo para DataPrime:

Anexo 5 · Rúbrica de evaluación (instructor)

Criterio	Logrado (3)	En proceso (2)	Por mejorar (1)	Evidencia
Propiedades de la seguridad	Relaciona correctamente los 5 incidentes.	Relaciona 3 o 4.	Relaciona menos de 3.	Anexo 1, A
Controles	Clasifica 10 o más prácticas.	Clasifica de 7 a 9.	Clasifica menos de 7.	Anexo 1, B
Cálculo de riesgos	Calcula los 5 riesgos y niveles y ordena la prioridad.	Un error de cálculo o de orden.	Varios errores.	Anexo 3
Controles y normas	Propone control, norma y responsable viables en cada hallazgo.	Propuestas generales o sin norma.	Sin propuestas.	Anexos 3 y 4
Reporte y trabajo en equipo	Expone en 3 minutos con claridad; todos participan.	Comprensible; participación desigual.	Exposición confusa.	Observación

Escala: 12 a 15 puntos = competente; 8 a 11 = en proceso; menos de 8 = requiere refuerzo. Ajuste los rangos a los criterios de su centro de formación.

Anexo 6 · Soluciones y orientaciones (instructor)

Momento 1 y 2

- **Parte A:** 1 confidencialidad; 2 integridad; 3 disponibilidad; 4 autenticidad; 5 trazabilidad.
- **Parte B:** 1 H · 2 S · 3 A · 4 C · 5 P · 6 A · 7 S · 8 H · 9 C · 10 P · 11 H · 12 P. La tarjeta 12 también puede aceptarse como A (control de acceso) si se justifica.

Momento 3: matriz esperada

Hallazgo	Riesgo	Nivel	Propiedad	Control sugerido (norma)	Prior.
H1	4 × 4 = 16	Alto	Confidencialidad	Permisos por rol y clasificación de la información (ISO 27001 A.5.12 y 5.15; Ley 1581, acceso restringido)	2
H2	4 × 5 = 20	Crítico	Disponibilidad e integridad	Plan de parches y gestión de vulnerabilidades (A.8.8)	1
H3	3 × 5 = 15	Alto	Confidencialidad y autenticidad	Revocar accesos el día del retiro (A.5.18 y 6.5); lista de chequeo de retiro	3
H4	3 × 3 = 9	Medio	Confidencialidad	Portal autenticado o PDF cifrado (A.8.24; GDPR art. 32; Ley 1581)	5
H5	2 × 5 = 10	Medio	Disponibilidad	Copias 3-2-1 y pruebas de restauración (A.8.13)	4

Orden de prioridad: H2, H1, H3, H5, H4. Acepte otro orden si se argumenta (por ejemplo, subir H3 por tratarse de un acceso indebido activo).

- **Mapa de defensa, ejemplos:** personas (capacitación, acuerdos de confidencialidad, procedimiento de retiro); física (control de ingreso al archivo); red (cortafuegos, VPN); equipo (cifrado de disco, parches); aplicación (MFA, roles); datos (cifrado, copias 3-2-1).
- **Mini-caso:** contener (pedir la eliminación y confirmación al destinatario), documentar la línea de tiempo, avisar al responsable y al oficial de datos, evaluar el alcance, informar a la SIC y a los titulares según la ley colombiana (verificar plazos vigentes) y, si hay personas en la UE, notificar a la autoridad dentro de 72 horas (lunes a las 10:00). Luego, corregir la causa (validación de destinatarios, cifrado).

Orientaciones

- Si sobra tiempo: pida que redacten una política de una línea sobre envío de datos personales.
- Si falta tiempo: entregue el cálculo de riesgos resuelto y concentre el momento en los controles.
- Referencias: guía «Retos del planeta Byteon» (Misión básica 4); ISO/IEC 27001:2022; Reglamento (UE) 2016/679; Ley 1581 de 2012; NIST CSF 2.0.